Secure By Design

EDUCATE. EMPOWER. SECURE THE FUTURE.

COURSE 1.3 / COMPANION WORKBOOK

Harden the baseline

OU design, DISA GPOs & STIG/SCAP verification

Design the organizational unit structure, apply the DISA STIG Group Policy package to the verified network core, and prove the result with before-and-after SCAP scans, reconciled checklists, and a documented exception record.

MATERIALS EDITION 1.1 / COURSE 1.3

Updated 8 October 2026 · sbd-harden-baseline

NAME _____ / DATE _____

© 2026 Secure By Design Team LLC.

START HERE / YOUR LEARNING PATH

Table of contents

Read each lesson alongside the interactive guide and the video. Use the record tables to write down what you actually observe — the workbook is your evidence, not the guide.

Before you start

01 Design and build the OU structure

02 Stage the tooling across the air gap

03 Capture the pre-hardening baseline

04 Import and link the DISA GPOs

05 Rescan, reconcile, and record

06 Set the rescan cadence and exception record

Course review and sign-off

> **HOW TO USE IT** Each lesson page has the same shape: what you will learn, the build steps, the commands that verify them, and a record table. Fill the table from your own environment — never from the sample values.

Before you start

This course designs the organizational unit (OU) structure, applies the Defense Information Systems Agency (DISA) Security Technical Implementation Guide (STIG) Group Policy package, and verifies the result with Security Content Automation Protocol (SCAP) scans. Paths, versions, and session locations below are examples — adapt them to your tooling. Expect STIG settings to change behavior: that is the point, and the reason everything is scanned and recorded.

Prerequisites

- ☐ Complete the identity build and DNS courses with replication and name resolution verified on both controllers.
- ☐ Use the isolated Windows Server 2025 environment and an account approved for organizational unit and Group Policy administration.
- ☐ Have an approved connected system and removable-media procedure for bringing downloaded hardening content into the lab.

What this course builds

- Design OUs for delegation and policy targeting, and redirect the default containers.
- Import the DISA GPO package and link STIG policies by organizational unit.
- Verify hardening with baseline and rescan SCAP results, reconciled checklists, and documented exceptions.

Systems in scope

RECORD	YOUR OBSERVATION
SBD-DC01 — name, address, OS build	
SBD-DC02 — name, address, OS build	

© 2026 Secure By Design Team LLC.

LESSON 01 / ABOUT 20 MIN

Design and build the OU structure

WHY THIS MATTERS Organizational units exist for delegation and Group Policy targeting, not to mirror an org chart. Build the structure the hardening policies will hang on before importing any of them.

In this lesson you will

- Design an OU structure around delegation and Group Policy targeting.
- Create protected OUs and redirect the default Computers and Users containers.
- Explain why the built-in Domain Controllers OU stays untouched.

Follow the build

1. Design the structure by administration: a top-level SBD OU containing Servers, Workstations, Users, Groups, and an Admin OU for privileged accounts. The built-in Domain Controllers OU stays where it is and keeps its name.
2. Create the planned OUs with accidental-deletion protection enabled. Record each OU's purpose and who will administer its contents; an OU with no delegation or policy purpose is clutter.
3. Redirect the default Computers and Users containers to managed OUs with redircmp and redirusr. Group Policy cannot be linked to the default containers, so anything landing there would get only domain-level policy, never the OU-linked hardening.
4. Keep privileged accounts and systems separate: the Admin OU holds the identities that administer domain controllers. The issuing CA from course 1.4 joins the Servers OU for now; course 1.7 gives Tier 0 servers their own OU. Do not nest deeper than the delegation plan requires.

Check your result

```
Get-ADOrganizationalUnit -Filter * | Select-Object Name, DistinguishedName
Get-ADDomain | Select-Object ComputersContainer, UsersContainer
(Get-ADOrganizationalUnit -Identity 'OU=SBD,DC=sbd,DC=test' -Properties
ProtectedFromAccidentalDeletion).ProtectedFromAccidentalDeletion
```

WHAT SUCCESS LOOKS LIKE The planned OUs exist with deletion protection, the default container redirects point at managed OUs, and each OU has a recorded purpose and administrator.

Your record

Evidence to keep: Keep the OU design sheet: each OU's distinguished name, purpose, delegated administrator, and the redirect commands with their output.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

What should drive the shape of the OU structure?

> **REMEMBER** OUs follow administration, not the org chart. The default containers are redirected so nothing joins unmanaged. The Domain Controllers OU remains the link point for DC policies.

Microsoft · New-ADOrganizationalUnit

Microsoft · Redirect the Users and Computers containers

LESSON 02 / ABOUT 15 MIN

Stage the tooling across the air gap

> **WHY THIS MATTERS** The hardening content is downloaded artifacts: the DISA Group Policy object (GPO) package, the SCAP Compliance Checker (SCC), and STIG Viewer. They cross the boundary the way everything does here — reviewed, hashed, and carried on approved removable media.

In this lesson you will

- Identify the DISA artifacts the hardening work needs.
- Move downloaded tooling across the air gap with hash verification.
- Record versions so scans stay comparable over time.

Follow the build

1. On an approved connected system, download the current DISA GPO package and the SRG/STIG tools (SCC and STIG Viewer) from DISA's public site. Note each file's version and the quarterly release it belongs to.
2. Record a SHA-256 hash for every file on the connected side, then transfer the set with the approved removable-media procedure. No live link to the lab is created for convenience.
3. In the lab, recalculate and compare every hash before opening anything. A mismatch stops the work, exactly as it would in the PKI signing ceremony.
4. Install SCC and STIG Viewer on an administrative host and stage the GPO package where the import lesson can reach it. Record tool versions; scan results are only comparable when the benchmark and tool versions are known.

Check your result

```
Get-ChildItem C:\Staging\DISA | Select-Object Name, Length
Get-FileHash -Algorithm SHA256 C:\Staging\DISA\*
```

> **WHAT SUCCESS LOOKS LIKE** Every transferred file's hash matches the value recorded on the connected side, and tool and package versions are written down.

Your record

Evidence to keep: Keep the transfer record: file names, versions, both hash sets, media custody, and the date.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Why hash the files on both sides of the transfer?

> **REMEMBER** The GPO package, SCC, and STIG Viewer come from DISA's public site. Hashes are recorded on both sides of the boundary. Tool and package versions are part of the evidence.

DISA · STIG Group Policy Objects package

DISA · SRG/STIG tools (SCC and STIG Viewer)

LESSON 03 / ABOUT 25 MIN

Capture the pre-hardening baseline

> **WHY THIS MATTERS** Measure before you change. A scan of the freshly built controllers shows the honest starting point, teaches what the operating system already secures by default, and becomes the before picture every later scan is compared against.

In this lesson you will

- Run a SCAP baseline scan against both domain controllers.
- Distinguish automated results from manual-review items.
- Preserve raw results as evidence with hashes and versions.

Follow the build

1. On each domain controller, run SCC with the Windows Server 2025 STIG benchmark and the directory-related content staged for this course. Save each session's results with the host name and date.
2. Open the results and read, don't just count. Note which checks already pass: Windows Server 2025 ships with defaults such as required signing on outbound SMB connections and LDAP sealing on new deployments, so part of the STIG is green before you touch anything.
3. Separate the automated results from the manual checks. SCAP answers what a scanner can read; items marked for manual review go to STIG Viewer for a human answer in lesson 5.
4. Store the raw result files unmodified, with recorded hashes. The baseline is evidence; a cleaned-up copy is a summary, not the record.

Check your result

```
# Adapt paths to your SCC installation and session directory.
Get-ChildItem C:\Evidence\baseline -Recurse -Include *.xml | Select-Object Name,
LastWriteTime
Get-FileHash -Algorithm SHA256 C:\Evidence\baseline\*
```

> **WHAT SUCCESS LOOKS LIKE** Both controllers have a dated baseline result set, the already-compliant OS defaults are noted, and the raw files are hashed and stored.

Your record

Evidence to keep: Keep the per-host result files, their hashes, the benchmark and tool versions, and a short note of what the OS defaults already covered.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Why scan before applying any GPO?

> **REMEMBER** The baseline is measured, dated, and stored unmodified. Secure-by-default items are recognized, not claimed as your work. Manual checks are queued for human review.

Microsoft · What's new in Windows Server 2025

DISA · SRG/STIG tools (SCC and STIG Viewer)

NIST · National Checklist Program (SP 800-70)

LESSON 04 / ABOUT 35 MIN

Import and link the DISA GPOs

WHY THIS MATTERS Group Policy is how the STIG becomes configuration. Import the package into the central store, link by organizational unit, and keep the lab's deliberate deviations written down rather than silently skipped.

In this lesson you will

- Stage the package's templates in the Group Policy central store.
- Import DISA's policies and link them by organizational unit.
- Handle lab-specific deviations with documentation instead of silent edits.

Follow the build

1. Copy the package's ADMX and ADML templates into the domain's Group Policy central store (the PolicyDefinitions folder in SYSVOL) so every editor on any domain controller shows the same settings.
2. Create empty GPOs named for the package's policies and import the package's settings into them with the GPMC Import Settings wizard or Import-GPO. Keep DISA's names with a local prefix so the source release stays identifiable.
3. Link the domain-controller policies to the Domain Controllers OU and the member-server policies to the Servers OU for future systems. Review link order and inheritance; do not use Enforced as a shortcut around understanding precedence.
4. Walk the settings that need a decision in this network — anything referencing infrastructure the lab does not have. Record each deviation with its rationale instead of deleting the setting, then update policy and confirm application.

Check your result

```
Get-ChildItem \\sbd.test\SYSVOL\sbd.test\Policies\PolicyDefinitions | Measure-Object
Get-GPO -All | Select-Object DisplayName, GpoStatus, ModificationTime
Get-GPInheritance -Target 'OU=Domain Controllers,DC=sbd,DC=test'
gpupdate /force
gpresult /r /scope:computer
```

WHAT SUCCESS LOOKS LIKE The central store serves the package's templates, the imported GPOs are linked to the intended OUs, gpresult shows them applying, and every deviation has a written reason.

Your record

Evidence to keep: Keep the import record: package release, GPO names and links, inheritance output, and the deviation list with rationale and owner.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	

RECORD	YOUR OBSERVATION
Differences from the plan	
Evidence file names	
Open items or findings	

Think it through

Why does the OU work from lesson 1 matter here?

REMEMBER The central store keeps policy definitions consistent across controllers. Links follow the OU design; precedence is understood, not forced. Deviations are documented decisions, not deletions.

Microsoft · Create and manage the Group Policy Central Store

Microsoft · Import-GPO

Microsoft · Gpresult

DISA · STIG Group Policy Objects package

LESSON 05 / ABOUT 35 MIN

Rescan, reconcile, and record

> **WHY THIS MATTERS** The second scan is the verdict. Compare it with the baseline, let the automated results fill the checklists, and give every remaining open item a human answer.

In this lesson you will

- Re-scan with matched benchmark and tool versions and compare against the baseline.
- Populate checklists from scan results and answer manual checks with evidence.
- Classify every remaining open item explicitly.

Follow the build

1. Rerun SCC on both controllers with the same benchmark and tool versions as the baseline. Changing versions between scans makes the comparison meaningless.
2. Compare the two result sets per host: which checks moved from open to compliant, which stayed open, and whether anything regressed. Attribute each change to the policy that caused it.
3. Create the course checklists in STIG Viewer and bring in the scan results so automated passes are populated. Work the manual-review items one by one, recording the observed evidence for each answer.
4. Classify what remains open: a finding to fix now, a documented deviation from lesson 4, or a candidate for a Plan of Action and Milestones (POA&M) — the artifact the Body of Evidence course teaches you to write.

Check your result

```
# Compare result sets; adapt paths to your evidence layout.
Get-ChildItem C:\Evidence\baseline, C:\Evidence\hardened -Recurse -Include *.xml | Select-Object Directory, Name
Get-FileHash -Algorithm SHA256 C:\Evidence\hardened\*
gpresult /h C:\Evidence\hardened\SBD-DC01-gpresult.html
```

> **WHAT SUCCESS LOOKS LIKE** Both hosts show the expected movement from the baseline, every change is attributable, and every open item is a finding, a deviation, or a POA&M candidate — never unexplained.

Your record

Evidence to keep: Keep the before/after comparison, the populated checklist files, manual-check answers with their observed evidence, and the classification of remaining opens.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	

RECORD	YOUR OBSERVATION
Evidence file names	
Open items or findings	

Think it through

Why keep the same benchmark and SCC versions for the rescan?

> **REMEMBER** Same versions, honest comparison. Automated results fill the checklist; humans answer the rest. Open items end the lesson classified, never mysterious.

DISA · SRG/STIG tools (SCC and STIG Viewer)

NIST · National Checklist Program (SP 800-70)

LESSON 06 / ABOUT 20 MIN

Set the rescan cadence and exception record

> **WHY THIS MATTERS** Hardening is a state you maintain, not a step you finish. Close the course by deciding who rescans, when, and which event forces an early look.

In this lesson you will

- Consolidate deviations into an owned, dated exception record.
- Define the quarterly and event-driven rescan cadence.
- Export and back up the applied policy state as evidence.

Follow the build

1. Consolidate the deviation records into one exception list: setting, reason, risk note, owner, and review date. This list travels into the authorization path as part of the Body of Evidence.
2. Set the standing cadence: review each quarterly DISA release for applicable updates, and rescan after any role addition or significant configuration change. Course 1.5's closing delta scan is the first scheduled instance, and course 1.6 scans the PKI servers the same way.
3. Export the Group Policy reports and back up the GPO set so the applied policy state is recoverable and reviewable without a live console.
4. Write the handoff note a future administrator or assessor would need: where the evidence lives, which versions produced it, and what is intentionally open.

Check your result

```
Get-GPOReport -All -ReportType Html -Path C:\Evidence\gpo-report.html
Backup-GPO -All -Path C:\Evidence\gpo-backup
Get-FileHash -Algorithm SHA256 C:\Evidence\gpo-report.html
```

> **WHAT SUCCESS LOOKS LIKE** The exception list has owners and review dates, the GPO set is exported and backed up, and the rescan triggers are written where the next course will meet them.

Your record

Evidence to keep: Finish the hardening checklist: exception list, GPO backup location, report hashes, the cadence, and the named owner of the next review.

RECORD	YOUR OBSERVATION
Host(s) and time collected	
Observed result	
Differences from the plan	
Evidence file names	

RECORD	YOUR OBSERVATION
Open items or findings	

Think it through

What triggers a rescan before the next quarterly cycle?

REMEMBER Exceptions have owners and review dates. Rescans follow the DISA quarter and every meaningful change. The applied GPO state is exported, backed up, and hashed.

DISA · STIG Group Policy Objects package

NIST · National Checklist Program (SP 800-70)

Course review and sign-off

Before moving on, confirm each lesson left evidence behind — and that what remains open is written down, not remembered.

Lesson completion

LESSON	EVIDENCE FILED	DATE
01 Design and build the OU structure	☐ yes	
02 Stage the tooling across the air gap	☐ yes	
03 Capture the pre-hardening baseline	☐ yes	
04 Import and link the DISA GPOs	☐ yes	
05 Rescan, reconcile, and record	☐ yes	
06 Set the rescan cadence and exception record	☐ yes	

Open items carried forward

Next in the learning path

That completes hardening the baseline. Course 1.4 builds the two-tier PKI on this hardened base, and course 1.5 runs this cadence's first delta scan.

> **KEEP IT HONEST** Lesson completion records learning activity; it is not a system authorization decision. Your observations, not the sample values, establish what happened in your environment.

© 2026 Secure By Design Team LLC.